NAIF KHALID ALSALEM

GRC Methodology Handbook

How I work: steps, rules and worked examples from the Qayrawan Information Systems case study

Document ID	NAS-HBK-001
Version	0.1 (Draft)
Date	7 November 2026
Nature	Personal reference and a showcase of how I work
Author	Naif Alsalem

Sources. Chapters 1 to 7 are built on my own work in the GRC bootcamp, and each chapter names its source at the start. Chapters 8 to 10 are outlines I write myself from our discussions, and are not filled in yet.

Examples. Qayrawan Information Systems (QIS) and its clients are fictional. The frameworks and regulators are real, and control numbers are checked against their official texts.

Language. Translated from the Arabic lead text. In case of conflict, the Arabic text prevails.

How to use this handbook

Every chapter has the same sections, so I can find what I need quickly:

Section	What it holds
When to use it	The situation the method fits.
Steps	What I do, in order.
Rules	What I don't compromise on, and the mistakes I avoid.
QIS example	The method applied to the case study, with the document ID.
Source	The work the method was taken from.

#	Chapter	Status
1	Risk assessment and the 5×5 register	Draft
2	Attack trees	Draft
3	Threat modelling with STRIDE	Draft
4	Classifying security controls by function	Draft
5	Designing KPIs and KRIs	Draft
6	Business impact analysis and recovery objectives	Draft
7	Writing a policy and procedure	Draft
8	Estimating likelihood without data	Outline, for Naif to write
9	Impact scales	Outline, for Naif to write
10	Risk appetite and acceptance authority	Outline, for Naif to write

1. Risk assessment and the 5×5 register

Source: risk assessment of Alinma Bank's e-banking system (June 2026).

When to use it

When assessing the risks of a system, a service or a whole organization, and when building or updating the risk register.

Steps

- **Group risks into categories** before scoring them, because grouping shows what you missed. For Alinma I used two: the system, its operation and the team running it; and the users and their awareness.
- **Give each risk a fixed code** that shows its category (A1, B1), and a short description of what happens and why.
- **Map each risk to the matching controls** in the frameworks that apply (the Essential Cybersecurity Controls, and the central bank framework where relevant), checking the subdomain number against the official release.
- **Score likelihood and impact** from 1 to 5 and multiply them: Risk = Likelihood × Impact.
- **Set the level** from the bands in the table below, then rank risks from highest to lowest.
- **Detail the top risks**: for each top-priority risk, a table of causes, treatment plan and strategy (mitigate, transfer, avoid or accept).
- **Close with conclusions and recommendations**: how many risks, the highest ones, and the key actions.

Level	Range
Catastrophic	20 to 25
High	15 to 19
Medium	8 to 14
Low	3 to 7
Very low	1 to 2

Rules

- I don't score a risk I haven't written clearly as cause, event and impact.
- Control mapping comes before treatment, because it shows where the gap is.
- The treatment plan addresses the cause in the table, not the symptom.
- A strategy can combine two options, such as mitigation with partial transfer for denial-of-service attacks.

QIS example

The QIS risk register (QIS-RR-001) spreads 20 risks across categories. R-01 (ransomware spreading through the remote management tool into client networks) scored the highest level, and its treatment is detailed in the Incident Response Plan and the Business Continuity Plan.

> **For discussion:** I named the top band "Catastrophic" in the Alinma assessment, and it is "Critical" in the QIS methodology. I pick one name and use it across all documents.

2. Attack trees

Source: Alinma Bank risk assessment, section 7 (attack tree for risk A2, API vulnerabilities).

When to use it

For a single high-level risk where I need to understand in detail how it could happen, so I can place a control on every path.

Steps

- **Write the attacker's goal** in one sentence at the top of the tree. Alinma example: unauthorized access to the APIs to steal customer data or take their money.
- **Branch the main paths** and set how they relate: OR if any one path succeeding is enough, AND if all must succeed.
- **Fill in the path table**: the path, its type, the essence of the attack, the angle it exploits, and the countering controls.
- **Draw the tree** after the table. The table is the analysis, and the drawing illustrates it.

Path	Type	Essence	Controls
Authentication bypass	Token theft or forgery; missing ownership checks (BOLA)	"I am not me"	Identity and access management
Injection and exploitation	SQL or NoSQL injection, command injection, exploiting a shadow API	Reaching the database	Application security and a web application firewall
Business logic abuse	Bypassing transaction limits; no rate limiting	Using the system against itself	API gateway controls and server-side validation

Rules

- Every path ends in a control, or the tree is incomplete.
- A path with no control is the first item in the treatment plan.

QIS example

The first candidate for an attack tree at QIS is Client A's citizen portal, with the attacker's goal being exposure of citizen data through the APIs (scenario C-3 in QIS-IRP-001). The tree has not been drawn yet.

3. Threat modelling with STRIDE

Source: Alinma Bank risk assessment, section 8.

When to use it

When designing or reviewing a system before launch, and when adding a feature that crosses a new trust boundary.

Steps

- **Draw the data flow**: the user, the edge, the application server and the data.
- **Mark the trust boundaries**, because threats appear where data crosses them. At Alinma: between the untrusted client zone and the internet, and between the application server and the internal data zone.
- **Walk through all six categories** at each boundary, and write down where each threat occurs and the countering control.

Category	Where it occurs (Alinma example)	Countering control
Spoofing	Trust boundary 1: client to edge	Multi-factor authentication
Tampering	Transport and application server	TLS and input validation
Repudiation	Application server	Tamper-proof audit logs
Information Disclosure	Trust boundary 2: application to data	Encryption and application security
Denial of Service	Trust boundary 1: the edge	Web application firewall, rate limiting and a continuity plan
Elevation of Privilege	Application server and data	Privileged access management and least privilege

Rules

- Every untreated threat is recorded as a risk in the risk register.
- STRIDE answers "what could happen"; the matrix in chapter 1 answers "how serious is it".

QIS example

The QIS Risk Management Methodology (QIS-RMM-001, section 5) requires STRIDE for every application QIS builds or hosts that processes personal or classified data, starting with the citizen portal. The AI Usage Policy (QIS-POL-002, clause 5.5) adds prompt injection and data leakage through outputs.

4. Classifying security controls by function

Source: the "Classifying Different Security Controls" exercise, July 2026, with Mohammed Al-Sheikh.

When to use it

In gap analysis and when choosing a treatment, to make sure a risk doesn't rely on only one kind of control.

Categories

Category	What it does
Preventive	Stops the incident before it happens.
Detective	Finds the incident while it happens or after.
Deterrent	Discourages the attacker from trying.
Corrective	Repairs the damage and restores the state after the incident.
Compensating	A temporary or partial substitute when the primary control can't be applied.

My classification

Control	Category
Firewall, network segmentation, application whitelisting, email filtering	Preventive
Access controls, encryption, data loss prevention, endpoint protection	Preventive
Patch management, security training and awareness	Preventive
Intrusion detection, SIEM, file integrity monitoring	Detective
Vulnerability scanning, penetration testing, manual review, enhanced monitoring	Detective
Warning messages, legal notices, publicized policies, visible security measures	Deterrent
Incident response plan, backup and recovery, vulnerability management	Corrective
Forensic analysis	Corrective, can be detective
Temporary restriction	Compensating
User activity monitoring	Compensating, also detective
Log monitoring	Compensating
Honeypots	Preventive, can be detective

Rules

- A high risk needs at least one preventive and one detective control, then a corrective control that sets how we recover.
- A compensating control is temporary: record why the primary control can't be applied and when it will be reviewed.

> **For discussion before 1.0:** some references put honeypots and log monitoring under detective controls, and vulnerability management under preventive. I review these three and decide whether to keep my classification and write down why, or change it.

QIS example

For R-01 in the QIS risk register: multi-factor authentication on the remote management tool is preventive, the managed SOC is detective, immutable backups are corrective, and manually switching the tool off until segmentation is complete is compensating.

5. Designing KPIs and KRIs

Source: the Cybersecurity KPI and KRI Dashboard (January to June 2026), group work, and SecureTech's Data Protection Policy.

When to use it

When attaching indicators to each policy clause, and when building a reporting dashboard for senior management.

The core rule

	KPI	KRI
Measures	How well a control performs	How close we are to the risk appetite limit
Target or threshold	Reactive: follows actual performance	Fixed: represents the risk appetite
After a bad month	Next month's target may rise, then come down step by step	The threshold never rises, because raising it means accepting more risk
When breached	Follow up and correct	Escalate immediately, which is what the indicator is for

The reactive target formula

Target = last month's actual ± an improvement step, bounded by a floor or cap that is the final target. Examples from the dashboard:

Indicator	Formula	Bound
Mean time to detect	Last actual minus 0.2 hours	Not below 2.5 hours
Mean time to respond	Last actual minus 0.35 hours	Not below 6.5 hours
Patch compliance	Last actual plus 2 points	Not above 98%

Dashboard sections

- Current status against final targets and thresholds.
- KPI trends with their reactive targets.
- KRI trends with their fixed thresholds.
- Irregular trajectories and their root causes (such as the March spike: new assets without monitoring, a lifted change freeze, staff shortages, and detection rule tuning).
- Gap to target, and the safety margin left before the threshold.
- Top improvers.
- The full data table.
- Actions needed.

Rules

- Every policy clause carries a KPI or KRI table, or both.
- One colour key (green, amber, red) across all documents, with the meaning of each colour and the action it calls for.
- Every indicator has a code, a definition, a target or threshold, and a measurement frequency.

QIS example

The rule is applied in the QIS-KPI-001 dashboard (illustrative data, December 2026 to May 2027), and in the indicator tables attached to the clauses of QIS-POL-001, QIS-POL-002 and QIS-CHR-001.

6. Business impact analysis and recovery objectives

Source: the Al Harbi Bank Business Continuity Plan and Incident Response Plan (master copy).

When to use it

When preparing or reviewing a Business Continuity Plan, and when negotiating service levels with clients.

Terms

Term	Meaning
RTO: recovery time objective	The longest time allowed to restore a service after it stops.
RPO: recovery point objective	The most data that can be lost, measured in time.
MAO: maximum acceptable outage	The point after which the damage becomes unacceptable.

Steps

- **List the services** and set, for each, the client and the impact of an outage.
- **Set the maximum acceptable outage** from the impact, then the RTO clearly below it, and the RPO from how fast the data changes.
- **Rank priorities** by the objectives: shortest first.
- **Prepare a continuity matrix** for each priority service.

In the Al Harbi Bank plan, the RTO was half the maximum outage or less in every scenario (such as 1 hour against 2, 30 minutes against 1 hour, and 4 hours against 8). QIS applies the same rule.

Continuity matrix fields

Field	What goes in it
Description	What the service is and who it is for.
Dependencies	The systems, suppliers and people it relies on.
Scenarios	What could stop it.
Risk level	From the risk register, with the risk numbers.
Proactive measures	What we do now to reduce the impact.
During the incident: continuity	How the service keeps running at a minimum level.
During the incident: recovery	The order of restoration.
After the incident	Checks, fail-back and lessons learned.
Objectives and owners	RTO, RPO and MAO, the owner, and who reports.

QIS example

In QIS-BCP-001 the citizen portal has a maximum outage of 8 hours, an RTO of 4 hours, an RPO of 15 minutes, and priority 1. These values remain proposals until they are matched against Client A's contract.

7. Writing a policy and procedure

Source: SecureTech's Data Protection Policy, and the AI Usage Policy and Procedure.

Policy structure

#	Section	Note
1	Document control	Owner, reviewer and approver, version history, and review cycle.
2	Indicator colour key	Once, at the start of the document.
3	Definitions	Every term used with a specific meaning.
4	Purpose and scope	What the policy protects, who it applies to, and what is out of scope.
5	Principles	Where needed, as in the AI policy.
6	Policy statements	Numbered clauses, each followed by an indicator table.
7	Roles and responsibilities	A RACI matrix.
8	Procedure	A table of steps: responsible party, output and duration.
9	Consequences of non-compliance	
10	Review, references and contact	

Rules

- A clause is written as a measurable obligation, or it can't be audited.
- The policy says "what" and the procedure says "how". They can share one document in two separate parts.
- RACI: only one Accountable party per activity.

QIS example

QIS-POL-001 Data Protection Policy, and QIS-POL-002 AI Usage Policy and Procedure.

8. Estimating likelihood without data

> **Outline for Naif to write.** Built on our discussion of risk R-01. The starting point is the order of evidence I set: has it happened in our workplace before? Are there industry numbers? If neither, we set a number with sound reasoning.

Questions this chapter answers

- What is my definition of likelihood? (We agreed it is a measure of chance, whether expressed as probability or frequency.)
- What is the order of evidence sources, and why that order?
- Without data, which factors do I assess, and how do I combine them into one number?
- Why did I choose 3 for R-01 despite how dangerous it is, and when do I re-estimate it?
- How do I document the reasoning so someone else can review it?

My text

(to be written)

9. Impact scales

> **Outline for Naif to write.** The impact scales in QIS-RMM-001 are a draft I added to complete the document, and they need your review and wording.

Questions this chapter answers

- Which impact dimensions do I measure (financial, operational, regulatory, data, reputation)?
- How do I set the limits for each level, especially the financial amounts?
- Why take the highest dimension rather than the average?

My text

(to be written)

10. Risk appetite and acceptance authority

> **Outline for Naif to write.** The risk appetite and acceptance authority table in QIS-RMM-001 are a draft I added, and they need your review and wording.

Questions this chapter answers

- How do I express risk appetite for an organization serving government clients?

- Who accepts each risk level, and for how long?
- How do fixed KRI thresholds tie to the risk appetite? (See chapter 5.)

My text

(to be written)